KRKL

SECURITY REPORT

PLUSQUAM SECURITY REVIEW

Security Audit & Remediation Report

Nine security findings, all fixed and verified on the staging environment.

9/9	11	0	4
findings fixed	checks passed	known dependency vulnerabilities	alarms monitoring the system

PROJECT	Plusquam web application
REPORT DATE	24 October 2026

SUMMARY

Executive summary

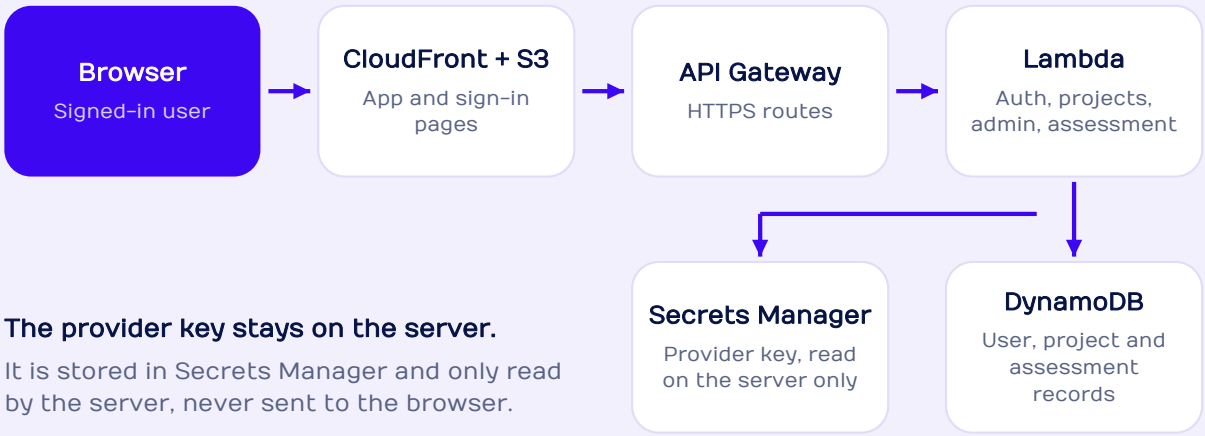
All nine findings are fixed and verified on the deployed staging environment.

OUTCOME

Every security check in this report passed: sign-in, access control, uploads, browser settings, secrets, data encryption, rate limits and monitoring.

The highest-priority fix replaced a long-lived login token in the web address with a one-time code that expires after 60 seconds. Other fixes limit login attempts, restrict each project to its owner, check uploaded files on the server, keep the provider key off the browser, and add browser security headers.

HOW A REQUEST TRAVELS



The provider key stays on the server.

It is stored in Secrets Manager and only read by the server, never sent to the browser.

WHAT WAS CHECKED

IDENTITY

Unauthenticated and deleted-account requests return 401. Repeated logins return 429.

TENANT ISOLATION

Cross-user project and report requests return 404.

BROWSER BOUNDARY

Unapproved origins are blocked. No provider key in the browser.

OPERATIONS

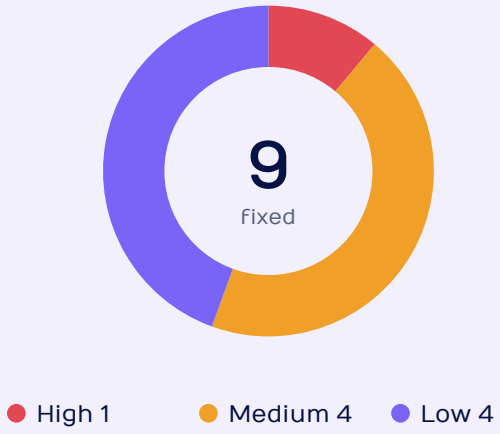
Four alarms, 30-day log retention, alert delivery tested.

FINDINGS

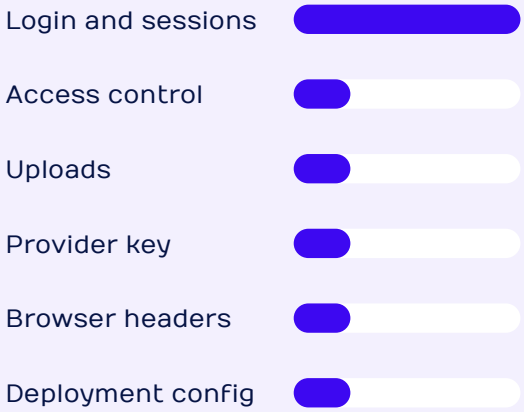
Findings at a glance

Nine findings, grouped by severity and by area. All are fixed.

BY SEVERITY



BY AREA



ALL FINDINGS

F01	JWT passed in URL fragment	HIGH	Fixed
F02	No login brute-force controls	MEDIUM	Fixed
F03	No owner check on project reads	MEDIUM	Fixed
F04	Provider API key exposure risk	LOW	Fixed
F05	Upload type checked only on client	LOW	Fixed
F06	Deletion did not invalidate sessions	MEDIUM	Fixed
F07	Login code stayed in browser history	MEDIUM	Fixed
F08	No CSP or security headers	LOW	Fixed
F09	API URL hardcoded in sign-in script	LOW	Fixed

FINDINGS

Findings and fixes

Each finding, what was changed, and how it was verified.

F01 JWT passed in URL fragment

HIGH

Replaced the long-lived token with a random single-use code that expires after 60 seconds. The sign-in page removes the code before exchange.

VERIFIED Login worked and the final URL kept no token or code.

F02 No login brute-force controls

MEDIUM

Added per-email and per-IP attempt limits, plus route throttling.

VERIFIED Repeated attempts were limited and returned HTTP 429.

F03 No owner check on project reads

MEDIUM

Added ownership checks for projects, assessment status, results and reports.

VERIFIED A second user could not see the first user's project. Direct read, assessment, edit, delete and report requests returned 404.

F04 Provider API key exposure risk

LOW

Moved provider credentials out of the browser and into AWS Secrets Manager.

VERIFIED Browser assets and network requests showed no provider key.

F05 Upload type checked only on client

LOW

Added server-side checks for file signature, extension, content type, size and extraction. The limit is 4 MB.

VERIFIED A malformed PDF returned HTTP 400. A file above 4 MB returned HTTP 413.

F06 Deletion did not invalidate sessions

MEDIUM

Account deletion changes the stored session version. Every request re-checks account status, role and session version.

VERIFIED The old token of a deleted account returned HTTP 401.

F07 Login code stayed in browser history

MEDIUM

The redirect replaces browser history and removes the one-time code before token exchange.

VERIFIED The final sign-in URL had no token or code.

F08 No CSP or security headers

LOW

Added Content Security Policy, HSTS and related headers to both CloudFront sites.

VERIFIED Both sites returned CSP, HSTS (one year), X-Frame-Options DENY, nosniff, a strict referrer policy and Permissions-Policy.

F09 API URL hardcoded in sign-in script

LOW

The deployment now writes a runtime config file with the API and app URLs.

VERIFIED The deployed sign-in and app used the configured API endpoint.

RESPONSES YOU WILL SEE

401	429	404	413
No token, or deleted account	Too many login attempts	Another user's project	Upload above the limit

CHECKS

Security checks

Run against the staging app and API.

Authentication Request without a token returned HTTP 401.	PASS
Session revocation A deleted user's token returned HTTP 401.	PASS
Role enforcement A normal user was denied the administrator view.	PASS
Login rate limit Repeated attempts returned HTTP 429.	PASS
Cross-user access User 2 could not see User 1's project. Direct requests returned 404.	PASS
S3 lockdown Public access blocked on both buckets. Only CloudFront can read.	PASS
CORS allowlist App and sign-in origins received the matching allow-origin header.	PASS
Unapproved origin An unapproved origin received no allow-origin header and was blocked.	PASS
Browser secret check No provider key in browser assets or network requests.	PASS
Security scan OWASP ZAP baseline scan of the app and sign-in sites. Passive scan.	PASS
Data at rest S3 and DynamoDB encrypted at rest, with point-in-time recovery enabled.	PASS

11 of 11 checks passed

SAFEGUARDS

Input and dependency checks

Server-side upload rejection, safe error handling and clean dependency scans.

UPLOAD VALIDATION

400 **Malformed PDF rejected**
A fake PDF failed signature validation.

413 **Oversize file rejected**
A file above the 4 MB limit returned the expected error.

REQUEST SIZE LIMIT



A 5 MB file sent as Base64 would pass the 6 MB platform limit before reaching the validator. At 4 MB, an oversized request reaches validation and is rejected cleanly.

MODEL OUTPUT HANDLING

Two invalid model-output attempts were stopped at assessment step 5 with a generic retry message. No raw model output or secrets were shown. Logs hold only the project reference, step and error type.

FAILS SAFELY

DEPENDENCIES

0
known vulnerabilities in the backend (pip-audit). pypdf upgraded to 6.21.2+.

0
vulnerabilities in the frontend (npm audit). Production build passed.

OPERATIONS

Monitoring and data protection

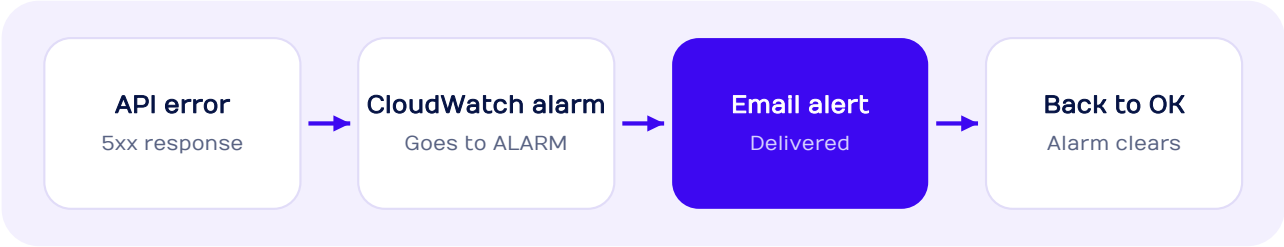
Alerts, logging and encryption were verified on staging.

4
CloudWatch alarms: API 5xx, assessment duration, assessment errors, login rate limit

30 days
log retention on all five Lambda log groups

Tested
a forced API 5xx alarm sent an email, then returned to OK

ALERT FLOW



Alert delivery was tested with a temporary subscription. Set the Plusquam operations email address for ongoing alerts.

DATA PROTECTION

AES256
encryption on both S3 buckets. Public access fully blocked.

KMS
encryption on the projects, assessments and users tables.

PITR
point-in-time recovery enabled on all three tables.

FINAL STATUS

All nine findings are fixed and verified on staging. Every security check in this report passed, including access control, rate limiting, upload rejection, data encryption, scans and alert delivery.